Exercise 01 — Network Reconnaissance (Nmap)

Overview

Date: 2026-03-07 **Attacker Machine:** Kali Linux (192.168.64.3) **Target Machine:** Basic Pentesting 1 / vtcsec (192.168.64.7) **Objective:** Simulate an attacker performing initial network reconnaissance and detect it using Splunk.

1. Objective

Network reconnaissance is the first step in almost every attack. Attackers use tools like Nmap to identify live hosts, open ports, running services, and operating system versions before deciding how to proceed. A SOC analyst's job is to detect this activity as early as possible — ideally before the attacker moves to exploitation.

2. Attack Execution

Initial Scan

A basic Nmap scan was first performed to identify the target host:
nmap -sV -sC 192.168.64.7

Aggressive Scan

A follow-up aggressive scan was performed to generate more log activity:
nmap -A -T4 192.168.64.7

Flags used:

Flag	Purpose
-sV	Service version detection
-sC	Default NSE script scanning
-A	Aggressive scan — OS detection, version detection, script scanning
-T4	Aggressive timing — generates high volume of traffic

Nmap Results

Port	State	Service	Version
21/tcp	open	ftp	ProFTPD 1.3.3c
22/tcp	open	ssh	OpenSSH 7.2p2 Ubuntu
80/tcp	open	http	Apache httpd 2.4.18

3. Log Evidence

Logs were captured on the target VM via rsyslog forwarding to Splunk. The following evidence was observed:

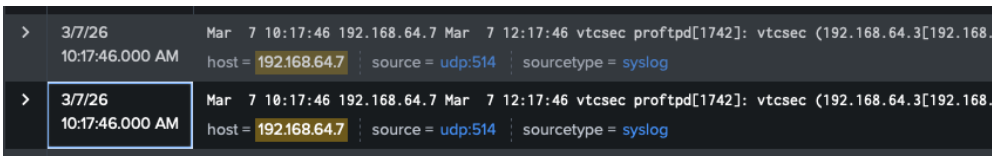
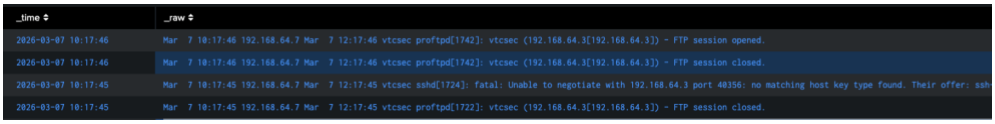
Nmap Signatures Identified in Logs

Timestamp	Log Entry	Significance

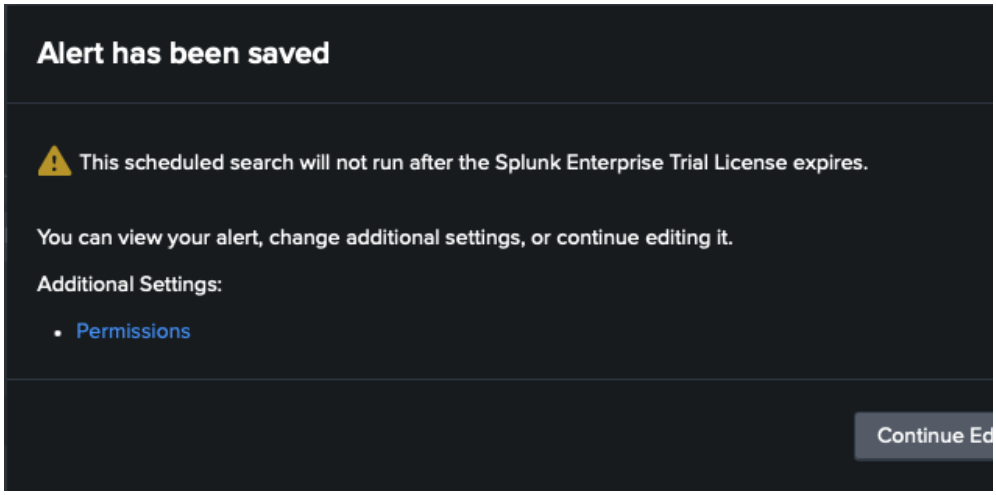
10:17:45	SSH-1.5-Nmap-SSH1-Hostkey	Nmap SSH version probe — tool identified by name
10:17:45	SSH-1.5-NmapNSE_1.0	Nmap scripting engine probe
10:17:45	Unable to negotiate — no matching host key type	Nmap testing multiple SSH key types
10:17:45	Protocol major versions differ	Nmap SSH1 vs SSH2 mismatch
10:17:45	Multiple FTP session opened/closed in <1 second	Nmap hammering FTP port 21
10:17:45	USER ftp: no such user found	Nmap attempting anonymous FTP login
10:17:45	Connection closed [preauth] x3	Nmap dropping connections after fingerprinting

Key finding: All scan activity occurred within an 8 second window (10:17:38 — 10:17:46), a burst pattern that is a strong indicator of automated scanning.

Screenshots

File	Description
screenshots/exercise01-nmap-proftpd-detection.png	
screenshots/exercise01-nmap-evidence-pt1.png	
screenshots/exercise01-nmap-evidence-pt2.png	

screenshots/exercise01-splunk-alert-saved.png



4. Detection

SPL Query

```
index=main host="192.168.64.7"
| search "Nmap" OR "no such user found" OR "Unable to negotiate" OR "Protocol major versions differ"
| stats count by host
| where count > 3
```

Query logic:

- Searches target VM logs for known Nmap scan signatures
- Counts matching events per host
- Filters out noise — only flags when more than 3 matching events are found
- Returned a count of **7** during this exercise

Splunk Alert Configuration

Setting	Value
Alert Name	Nmap Scan Detected
Schedule	Every hour
Trigger Condition	Number of results > 3
Trigger	Once
Expiration	24 hours
Severity	High
Action	Add to Triggered Alerts

> **Analyst note:** Severity was set to High rather than Critical. A port scan indicates reconnaissance activity and warrants immediate investigation, but does not confirm active exploitation. Critical severity is reserved for confirmed active threats such as ransomware or data exfiltration.

5. Response Notes

If this alert fired in a real SOC environment, the following steps would be taken:

1. **Identify the source IP** — Is 192.168.64.3 a known internal asset or unknown host?
2. **Check for follow-on activity** — Did the scanning IP attempt exploitation after the scan?
3. **Review firewall logs** — Was the scan blocked or did it reach the target?
4. **Escalate if needed** — If source IP is unknown or external, escalate to Tier 2
5. **Document the incident** — Log findings in ticketing system with timestamps and evidence

6. Key Takeaways

- Nmap identifies itself in SSH logs via its protocol strings — a reliable detection signature
- Burst patterns (multiple connections in under 8 seconds) are strong indicators of automated scanning
- Distinguishing attack traffic from background noise (e.g. DHCP renewals) is a core SOC analyst skill
- Automated alerts operationalize detection so analysts are notified without manual searching